

Threat Model for Hisnah

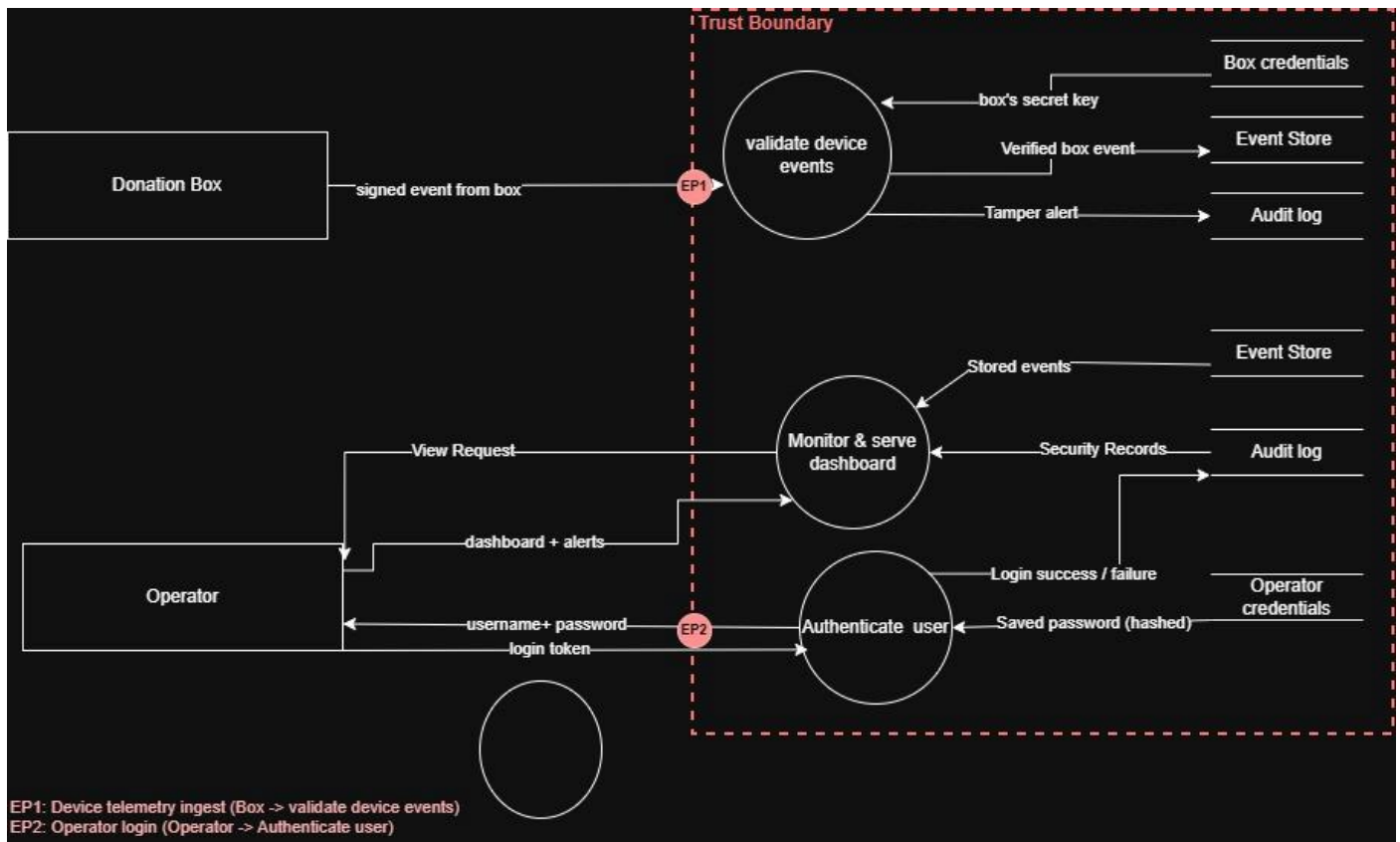
Element	Type	STRIDE	Threat	Control
Donation Box	External Entity	Spoofing	An attacker pretends to be a legitimate donation box and sends fake events to Hisna's system.	Each box has a unique secret HMAC key ; every event is signed with it, and the backend verifies the signature against the key in the Box credentials store.
Donation Box	External Entity	Repudiation	A box may send an event and then there is no way to prove where it came from	Every verified event is written to the Audit log with the box's identity and timestamp. Because the event was cryptographically proven to come from that box (via the HMAC), the log is trustworthy evidence of who sent what
Operator	External Entity	Spoofing	An attacker pretends to be the operator	BCrypt-hashed credentials verified over TLS, then a JWT binding the session to the authenticated operator.
Operator	External Entity	Repudiation	An operator performs an action opening the box / collecting donations, and later denies they did it, with no proof tying the action to them.	Every operator action is recorded in the Audit log against their authenticated identity (from the JWT) with a timestamp, so any collection or box-opening can be traced to the specific operator, they can't deny it.
Signed event from box	Data flow	Tampering	An attacker intercepts the event in transit and alters its contents . e.g. flips a "tamper" event into a "normal" one	HMAC-SHA-256 signature , the backend recomputes the HMAC over the message using the box's secret key, and any modification makes the signature fail, so the tampered message is rejected.
Signed event from box	Data flow	Information Disclosure	An attacker eavesdrops on the network and reads the event traffic (which boxes, when, what status).	TLS/HTTPS encrypts the channel so intercepted traffic is unreadable.
Signed event from box	Data flow	Denial of service	An attacker might sends a lot of fake events	Rate limiting per source + signature check ,unsigned/invalid floods are rejected immediately before processing.
Signed event form box	Data flow	Tampering (Replay)	An attacker copies a real message from the box and sends it again later to trick the system.	Each message has a one-time number (nonce) or a timestamp. The backend remembers the last one and rejects any repeated or old message.
box's secret key	Data Flow	Tampering	someone changes the stored secret key in the database.	database access control (only the app can read/write it)
box's secret key	Data Flow	Information Disclosure	an attacker who gets into the database reads the box's secret key (and could then fake that box completely).	the key is encrypted at rest, and the database is access-controlled
box's secret key	Data Flow	Dos	N/A - internal lookup, not exposed to attackers.	N/A
username + password	Data Flow	Tampering	Attacker alters login data in transit	TLS/HTTPS protects it in transit
username + password	Data Flow	Info disclosure	Attacker eavesdrops and reads the password	TLS/HTTPS encrypts it; sent only at login
username + password	Data Flow	DoS	Attacker floods login (brute-force / guessing)	Rate limiting + lockout after repeated failures
login token / JWT	Data Flow	Info disclosure	Attacker steals the token to reuse it	TLS in transit; token has a short expiry

Element	Type	STRIDE	Threat	Control
login token / JWT	Data Flow	Tampering	Attacker edits the token to change their role	JWT is signed by the server; any change breaks the signature → rejected
login token / JWT	Data Flow	DoS	---	N/A , single response, not floodable
view request + JWT	Data Flow	Tampering	Attacker alters the request or token	TLS + JWT signature check
view request + JWT	Data Flow	Info disclosure	Attacker eavesdrops on dashboard requests	TLS/HTTPS
view request + JWT	Data Flow	DoS	Attacker floods the dashboard	Rate limiting; valid JWT required, so junk is rejected
dashboard + alerts	Data Flow	Tampering	Attacker alters the data sent back	TLS protects integrity
dashboard + alerts	Data Flow	Info disclosure	Attacker reads sensitive alerts/box data	TLS; sent only to the authenticated operator
dashboard + alerts	Data Flow	DoS	---	N/A , covered by request-side rate limiting
verified box event	Data Flow	Tampering	Stored event altered in the database	DB access control; only the backend can write
verified box event	Data Flow	Info disclosure	Attacker who breaches the DB reads events	Access control; restricted to backend
verified box event	Data Flow	DoS	---	N/A , internal write
Tamper alert	Data Flow	Tampering	Attacker alters or deletes an alert in the log	Audit log is append-only / tamper-evident + access control
Tamper alert	Data Flow	Info disclosure	Attacker reads the security log	Access control; restricted to admins
tamper alert	Data Flow	DoS	---	N/A ,internal write
saved password (hashed)	Data Flow	Tampering	Stored hash altered in the DB	DB access control
saved password (hashed)	Data Flow	Info disclosure	Attacker steals the stored passwords	Stored as BCrypt hashes , useless if leaked + access control
saved password (hashed)	Data Flow	DoS	---	N/A --- internal read
login success/failure	Data Flow	Tampering	Attacker alters a login record	Append-only audit log + access control
login success/failure	Data Flow	Info disclosure	Attacker reads login history	Access control
login success/failure	Data Flow	DoS	---	N/A --- internal write
stored events	Data Flow	Tampering	Data altered before it's shown	DB access control
stored events	Data Flow	Info disclosure	Unauthorized reading of events	RBAC , only authorized operators; access control
stored events	Data Flow	DoS	---	N/A , internal read
security records	Data Flow	Tampering	Records altered before display	Access control
security records	Data Flow	Info disclosure	Sensitive security data exposed	RBAC, only admins see the audit log
security records	Data Flow	DoS	---	N/A, internal read

Element	Type	STRIDE	Threat	Control
Box credentials	Data Store	Tampering	An Attacker might manipulate box credentials form the database.	Set access control over the database, also the keys will be encrypted so any modification will be caught
Box credentials	Data Store	Info disclosure	An Attacker might get the box credentials	Keys are encrypted at rest + access control, so even if the database leaks, the keys can't be read.
Box credentials	Data Store	DoS	N/A	N/A
Operator credentials	Data Store	Tampering	An Attacker might change or modify the operator's credentials.	Set access control over who can edit and secure them
Operator credentials	Data Store	Info disclosure	An attacker might get the operator's credentials.	Passwords stored as BCrypt hashes + access control, so a database leak exposes only useless hashes.
Operator credentials	Data Store	DoS	An attacker might do a brute force to get the operator credentials	Limit the chances of logging in to be 3 times
validate device events	Process	Spoofing	An attacker might pretends to be a legitimate device	Each event must carry a valid HMAC signature made with the box's secret key; fake devices can't sign correctly
validate device events	Process	Tampering	An attacker might be in the middle of the validating process	HMAC signature + TLS ,any change breaks the signature.
validate device events	Process	Repudiation	a box/device sends an event and later there's no proof it did.	If any incident happened the audit log exist
validate device events	Process	Info disclosure	an attacker who breaks into the process could read box secret keys.	keys encrypted, access-controlled, kept in memory only briefly.
validate device events	Process	DoS	attacker floods it with fake events.	rate limiting + invalid signatures rejected cheaply before processing
validate device events	Process	Elevation of privilege	N/A	N/A
Authenticate user	Process	Spoofing	An attacker might pretend to be the legitimate operator	Apply MFA
Authenticate user	Process	Tampering	An attacker can add more user to be authenticated	Apply an access control
Authenticate user	Process	Repudiation	someone logs in and later denies it.	every login success/failure written to the audit log with identity + timestamp.
Authenticate user	Process	Info disclosure	User credentials might be leaked by an attacker	All communications and credentials are encrypted and secured
Authenticate user	Process	DoS	attacker floods the login endpoint / brute-forces passwords.	rate limiting + account lockout after repeated failures.
Authenticate user	Process	Elevation of privilege	An attacker might elevate privileges from an operator to system admin	RBAC ,the server checks the role in the JWT on every action, so an operator can't perform admin actions.
Monitor & serve dashboard	Process	Spoofing	attacker uses a stolen/forged token to appear logged in	valid signed JWT required
Monitor & serve dashboard	Process	Tampering	An attacker might have access to the dashboard and manipulate what it is showing	Apply access control for who can view the dashboard
Monitor & serve dashboard	Process	Repudiation	N/A	N/A
Monitor & serve dashboard	Process	Info disclosure	An attacker might see the status of each box through the dashboard	RBAC (only authorized roles see the dashboard/box data) + plus TLS

Element	Type	STRIDE	Threat	Control
Monitor & serve dashboard	Process	DoS	An attacker might apply a DoS attack to make the admin unable to serve the dashboard	If a huge number of requests are coming to the system , make an alert to the admin and block them as an initial step
Monitor & serve dashboard	Process	Elevation of privilege	a low-level operator tries to access admin-only data/actions on the dashboard	RBAC , server checks the JWT role on every request and blocks unauthorized access

Attack surface



Hisna's DFD model with attack surface

Aspect	Detail
Transport	Device connects to the server over HTTPS/TLS, so data in transit is encrypted and can't be read or modified by a network attacker.
Authentication	Every event is signed with HMAC-SHA-256 using a secret key shared between the box and server. The server recomputes the signature and rejects any event that doesn't match.
Integrity & replay protection	Each signed payload includes a timestamp/nonce. Resent or altered events fail the signature check, blocking replay and tampering.
Monitoring basis	This channel is the foundation of the monitoring plan: verified events go to the Event Store; failed signatures or replay attempts go to the Audit log and can raise a tamper alert.

- **EP1 – Device event ingest:** Donation Box sends a signed event across the trust boundary to "validate device events." This is the primary entry point from an untrusted, physically-accessible device.
- **EP2 – Operator login:** Operator submits username + password across the trust boundary to "Authenticate user." Standard credential-based entry point.